



Zayo Security Policy

Change History

Date	Version	Created by	Description of change
2023-12	0.1	Bryn Miller	Initial Draft
2024-01	0.2	Bryn Miller	Updated per CCF
2024-02	0.3	Cody Swidler	Review
2024-03	1.0	Shawn Edwards, Bryn Miller	Approve and Publish
2024-06	1.1	Bryn Miller	Revised section 1 to include continual improvement of the ISMS
2024-08	1.2	Bryn Miller	Updates per leadership feedback
2024-12	1.3	Shawn Edwards	Review
2024-12	1.4	Bryn Miller	Updates per review feedback
2024-12	1.5	Shawn Edwards, Bryan Fleming	Review and Approve
2025-01	2.0	Bryn Miller	Publish
2025-02	2.1	Bryn Miller	Update to section 2
2025-03	2.2	Bryn Miller	Linked related documents
2025-04	3.0	Shawn Edwards, Bryn Miller	Approve and publish
2025-06	3.1	Bryn Miller	Updated transcription tool requirement in sections 5.6.6 and 5.6.7 and password requirements in section 5.8 and 5.8.1
2025-06	4.0	Shawn Edwards, Bryn Miller	Approve and publish



Table of contents

Change History	2
1. Purpose, scope and Users	5
2. Compliance and exceptions	5
3. Management responsibilities	6
4. Legal, statutory, regulatory, and contractual requirements	6
5. Policy requirements	6
5.1. Security Governance	6
5.2. Audit	6
5.3. Risk assessment	7
5.4. Data classification	7
5.5. Information retention and disposal	7
5.6. Acceptable use of assets	8
5.6.1. Prohibited activities	8
5.6.2. Authorizations for asset use	8
5.6.3. Taking assets off-site	8
5.6.4. Internet use	8
5.6.5. E-mail and other message exchange methods	10
5.6.6. Use of Zoom	11
5.6.7. Use of Artificial Intelligence (AI)	11
5.6.7.1. Additional considerations	12
5.6.8. Intellectual property and copyright	12
5.6.9. Mobile devices	13
5.6.9.1. Remote access	14
5.6.9.2. Bring Your Own Device (BYOD)	15
5.7. Handling of assets	15
5.7.1. Information transfer	16
5.7.2. Media handling	16
5.7.2.1. Management of removable media	16
5.7.2.2. Physical media in transit	16
5.7.2.3. Media sanitization and disposal	17
5.7.3. Return of assets	17
5.8. User passwords	17
5.8.1. Application service account passwords	18



5.9. Network security	19
5.10. Physical access control	19
5.11. Endpoint protection	19
5.11.1. Endpoint encryption	20
5.12. Incident response	20
5.13. Vulnerability and patch management	20
5.14. Log retention and management	21
5.15. Change management	21
6. Security awareness training	21
6.1. External User training	22
6.1.1. Vendors providing services onsite	22
6.1.2. Contributing contractors to Zayo deliverables	22
6.1.3. Contractors supporting Zayo	22
7. Release of Information	22
8. Control objectives	23
9. Roles and responsibilities	26
10. Definitions	29
11. Enforcement	32
12. Related documents	32
13. Validity and policy management	33

1. Purpose, scope and Users

Zayo Group and its subsidiaries and Zayo Europe and its subsidiaries ("The Organization") are committed to the continual improvement of the Information Security Management System (ISMS) and meeting and maintaining appropriate security policies, standards, and procedures in alignment with its business strategy and mission. Using a Common Control Framework (CCF), the Organization is able to ensure compliance with regulatory requirements, industry best practices, and other authoritative sources as defined by various leading global organizations. The Organization's CCF is structured around various control families or domains, with each family representing a group of related controls from multiple regulations or standards, aligning them based on their common objectives and functional areas.

All information resources and information systems owned by the Organization must be protected from unauthorized disclosure, use, modification, or destruction in a manner consistent with their value, sensitivity and criticality to the business. The Organization shall institute a Security program to define the overall Security policy and direction. This Policy supports that program by providing high-level requirements to be followed by personnel so that the Organization remains fully compliant to required standards and regulations. Detailed requirements may be found within the supporting Standards of this Policy. For more information, refer to [Control objectives](#). These Control Objectives establish the guidelines and rules for Organizational procedures that will ensure the confidentiality, integrity, and availability of the Organization's information and resources.

Users of this Policy are employees, contractors, vendor workers, and interns of the Organization, and will be referred to as "User" throughout all Security documentation.

Vendors and partners will be referred to as "Supplier" throughout all Security documentation. Suppliers are subject to compliance with the portions of this Policy relative to their services as agreed upon contractually.

2. Compliance and exceptions

Failure to comply with Organizational policies and standards may lead to discipline up to and including termination of employment without notice, and if appropriate, Zayo will pursue all available legal remedies. Employees should notify their manager, Human Resources, Legal or management upon learning of any violations of Zayo policies and standards.

In certain circumstances, exceptions to this Policy may be allowed based on demonstrated business need, or to apply local relevant laws and regulations. Exceptions to this Policy must be formally documented and approved by the Security team and will be treated as issues as part of the Risk Management program. Issues created from policy exceptions must have a remediation plan and may result in a risk for assessment, remediation, or acceptance by a control owner.

3. Management responsibilities

It is the responsibility of management and Human Resources to ensure that Users are properly briefed on and comply with the Organization's security policies and standards.

It is the responsibility of management to ensure the training, awareness, and competency of individuals is kept up to date and relevant to the services, activities, and products provided by the Organization.

4. Legal, statutory, regulatory, and contractual requirements

All Users are responsible for compliance with all relevant legislative statutory, regulatory, contractual requirements in the relevant countries where the Organization conducts business. The Legal team must notify the responsible owner or team for compliance upon awareness of any new legal, regulatory, contractual or other requirement that might be relevant to information security and business continuity management.

5. Policy requirements

5.1. Security Governance

The Organization shall ensure security governance provides strategic direction, ensures that objectives are achieved, manages risk appropriately, uses organizational resources responsibly and monitors the success or failure of the enterprise security program.

There are four main functions of Security Governance:

- **Strategy** – aligning with business objectives
- **Implementation** – commitment, resources, assignments of responsibilities and implementation of policies and procedures as well as buy-in from senior management
- **Operation** – adequate resources are in place aligning with the strategy
- **Monitoring** – ensuring the effectiveness of the program

Security Governance shall include a steering committee that meets at regular intervals to discuss priorities, risk treatment plans, and metrics.

5.2. Audit

The Organization shall ensure that the control environment is adequate by conducting periodic audits. The results of these audits shall be discussed with Senior Management and presented in the steering committee meetings.



5.3. Risk assessment

The Organization shall regularly identify, define, and prioritize risks to the confidentiality, integrity, and availability of its information and systems. The risk assessment will be used to identify, select, and implement appropriate and reasonable technical and procedural controls to protect the confidentiality, integrity, and availability of information systems.

The specific objectives of this Policy and related Standards are to:

- Prevent unauthorized access, use, disclosure, modification, manipulation, or destruction to information systems.
- Ensure physical and logical security controls are properly implemented and managed.
- Ensure technology owners are aware of their respective responsibilities about systems' security and privacy compliance
- Manage information systems in a cost effective and efficient manner

For more information, see the [Audits and Risk Management Standard](#).

5.4. Data classification

Data Custodians and Data Owners, in conjunction with the security personnel, should periodically review data under their control to ensure it is appropriately classified. Likewise, controls associated with each classification should also be reviewed to ensure that they are still appropriate for the classification they protect. For any questions/concerns, please contact Security.

Users are responsible for executing due care and safeguarding information. Strict control must be maintained over the internal or external distribution of any kind of media that contains Restricted, Confidential, and Internal Use information.

For more information, see the [Records Management Standard](#).

5.5. Information retention and disposal

The Organization shall retain and dispose of "Confidential" and "Internal Use" information and data in accordance with business obligations, and applicable legal, and regulatory requirements and by the guidelines set forth in its Standards.

For more information, see the [Records Management Standard](#) and [Physical and Environmental Protection Standard](#).

5.6. Acceptable use of assets

Assets shall be used only for business needs with the purpose of executing organization-related tasks. Users are responsible for the use of their asset(s) and of any such use carried out under their responsibility.

Users and external parties using or having access to the Organization's assets must be made aware of the information security requirements of the Organization's assets associated with information and information processing facilities and resources. The Organization shall enhance external party oversight by requiring regular audits and certifications to strengthen compliance and reduce risks related to Supplier dependencies.

5.6.1. Prohibited activities

It is prohibited to use assets in a manner that unnecessarily takes up capacity, weakens the performance of the asset or poses a security threat.

Users must not use proxy anonymizers to attempt to mask the activities or bypass corporate controls.

5.6.2. Authorizations for asset use

Users may only access those information system assets for which they have been explicitly authorized by the asset owner.

Users must not take part in activities which may be used to bypass information system security controls. Users must use the asset only for purposes for which they have been authorized, i.e. for which they have been granted access rights.

5.6.3. Taking assets off-site

Equipment, information or software, regardless of its form or storage medium, may not be taken off-site without prior written permission from the appropriate manager. This includes removable media which is expected to be kept in a safe and secure environment, and in accordance with the manufacturer's specification. This excludes laptops and mobile devices which are an integral working tool.

As long as said assets are outside the Organization, they have to be controlled by the person who was granted permission for their removal.

5.6.4. Internet use

The Internet must be accessed only through the Organization's network with appropriate infrastructure and security protections.

Users must regard information received through unverified websites as unreliable. The Security team reserves the right to block access to some Internet pages for individual Users, groups of Users or all Users at the Organization. If access to web pages with a business use is blocked, Users must document the request to the Security team to have authorization to access such pages. Users must not bypass such restrictions. The Security team will always block access to the Internet from high risk countries.

Users must not utilize Internet resources to:

- Violate any laws or regulations
- Store or transmit objectionable material, images or content, including data, images, audio files, and video files where the transmission is illegal or otherwise violates the Organization's policies
- Interfere with normal business activities and operations
- Create, upload, download, display or access knowingly sites that contain pornography, games, gambling, dating, hacking, offensive images/videos/text, or other "unsuitable" material that can be considered obscene, criminal, defamatory, discriminatory, violent, harassing or hateful
- Subscribe to enter or use online gaming or betting sites
- Subscribe to money making sites or enter or use money making programs that aren't provided currently by the Organization (i.e. for corporate benefits).
- Download, distribute or install software programs not previously approved or any software that does not comply with our Policy. If you are unsure whether a program is approved, contact the Service Desk.
- Run a private business

Users are responsible for all possible consequences arising from unauthorized or inappropriate use of Internet services or content on a personal device. Any incidents related to malicious internet usage, must be reported to the Security team.

Message exchange methods other than electronic mail also include download of files from the Internet, transfer of data via approved web or cloud based services, telephones, sending SMS text messages, portable media, and forums and social networks.

Electronic communications (i.e., email, instant messaging, Chatter, blogs, voicemail, social media, etc.) are not secure methods for sending Sensitive Information. Below are the requirements for Users to follow to help protect our systems:

- Sensitive information defined in the [Records Management Standard](#) sent outside the Organization must be marked with confidential mode tags. Information sent internally is encrypted automatically from Google account to Google account.

- Email messages may be stored even after being deleted, creating a record of conduct that may have to be turned over in a lawsuit or investigation. Therefore, communications must be professional, clear, and accurate.
- Do not open unexpected attachments, click on links in emails or instant messages, or respond to spam or chain emails. If you are unsure, please reach out to the Security team.
- Do not configure the Organization's email accounts to automatically forward messages to an external account.

5.6.5. E-mail and other message exchange methods

Organization information may be exchanged through approved internal electronic communication channels. Message exchange methods other than electronic mail also include download of files from the Internet, transfer of data via Gmail, Chatter, Salesforce, Zoom, telephones, sending SMS text messages, portable media, and forums and social networks.

The Security team determines the communication channel that may be used for each type of data, as well as possible restrictions on who is allowed to use communication channels, i.e. defines which activities are forbidden.

Users may only send messages containing true information. It is forbidden to send materials with disturbing, unpleasant, sexually explicit, rude, slanderous or any other unacceptable or illegal content.

Users must not use other forms of services for sharing without obtaining approval from the Security team prior to using external public services (such as instant messaging, or file sharing services).

Users must ensure that there is correct addressing (i.e. addressing the information to the intended recipient) and transportation of the message to make sure that the information was successfully received. Users must not set up automatic forwarding to external inboxes.

There may be possible restrictions regarding permissions to use the communication channels and the Security team has the right to define which activities are forbidden (in accordance with the [Acceptable use of assets](#)).

The Security team will work with other key stakeholders to ensure that controls are in place to protect confidential information, as defined in the [Records Management Standard](#), from unauthorized access.

Users must not send spam messages to persons with whom no business relationship has been established or to persons who did not require such information. Should a user receive a spam email, it must be reported to the Security team.

If sending a message with a confidentiality label, the user must protect it as specified in the [Records Management Standard](#).

Users must save each message containing data significant for the Organization's business using the method specified by the IT Department.

Each email message must contain a disclaimer, except messages sent through communication systems determined by the IT Department. Should a user post a message on a message exchange system (social networks, forums, etc.), they must unambiguously state that it does not represent the organization's viewpoint.

5.6.6. Use of Zoom

Zoom is the preferred software for video conferencing at the Organization. The following rules must be followed by all Users:

- Use a virtual background to hide personal or work-related information from accidental disclosure when having meetings with non Organizational participants.
- Users should use caution when posting information about a Zoom call. Do not post meeting IDs. Zoom meeting URLs should not be posted publicly or to non-Organizational forums or customer tickets. Access to a Zoom URL would allow unauthorized individuals to join an Organization's Zoom session.
- It is recommended that once participants are in a meeting, the meeting is "locked" to prevent others from joining.
- Zoom provides for a Personal Meeting ID - a Zoom meeting ID that is unique to the user. This Personal Meeting ID must be used sparingly, only when the user wants to set up an on-demand meeting using a meeting ID that can easily be remembered.
- Third-party meeting transcription tools should not be used with the exception of the approved Zoom transcription tool.

5.6.7. Use of Artificial Intelligence (AI)

The responsible use of Artificial Intelligence (AI) and Generative pre-trained transformers (GPT), such as ChatGPT, Bard, Otter.io, and other similar tools, is essential for maintaining a secure environment within our organization. AI is a powerful tool that can assist users in various tasks, but it is crucial to adhere to certain guidelines to ensure its responsible and safe usage.

- All interactions with AI must comply with legal and ethical standards. Users must refrain from engaging in any illegal activities or sharing sensitive information that could compromise security.
- Users must be mindful of the quality of information generated by AI and critically evaluate its outputs. AI must not be solely relied upon for making critical decisions, especially in areas such as legal, financial, or medical matters.

- It is vital to protect the confidentiality of data and user information. Many AI systems capture and retain data for re-training purposes, so sensitive data must not be shared with any such system unless previously reviewed and approved by your team. When using AI, Users must exercise caution when sharing sensitive or proprietary data and ensure that appropriate security measures are in place.
- Any vulnerabilities or concerns related to the use of AI must be promptly reported to the designated IT or security personnel for assessment and mitigation.
- Third-party meeting transcription tools should not be used with the exception of the approved Zoom transcription tool.

5.6.7.1. Additional considerations

- Access to AI must be limited to authorized personnel only. User access must be reviewed regularly to ensure that users still require access to the system.
- Any data generated by AI must be retained in accordance with the Organization's data retention policies. This includes any logs or records of interactions with AI.
- Regular training and awareness sessions must be conducted to educate users on the responsible use of AI and the risks associated with its usage. This could include topics such as data protection, social engineering, and phishing attacks.
- AI interactions must be monitored for unusual activity, such as excessive or suspicious queries, to identify potential security incidents.
- A clear incident response plan must be in place to address any security incidents related to AI usage. This must include a process for reporting incidents, investigating and containing the incident, and communicating with affected parties.
- If AI is used by third-party vendors or contractors, appropriate contractual language must be included to ensure that they adhere to the same security policies and procedures as internal personnel.

5.6.8. Intellectual property and copyright

The Organization shall have User agreements implemented to ensure compliance with legislative, regulatory and contractual requirements related to intellectual property rights and use of proprietary software products. This must include providing a confidentiality agreement at the time of hire which must define the legal use of software and information products that applies to all regions that the Organization's Users occupy. This agreement must be available for all Users to read and understand. Refer to the [Human Resources Management Standard](#).

Users must have the appropriate awareness of this procedure with the intent that if these standards are not followed, disciplinary action will be taken against the personnel responsible for the breach.

Users must only acquire software that is approved and from reputable sources in order to ensure the Organization is in compliance with copyright. Users must not make unauthorized copies of software owned by the Organization, except in cases permitted by law, by the owner, or the Security team. Users must not copy software or other original materials from other sources and are liable for all consequences that could arise under the intellectual property law.

All application and system owners are responsible for maintaining proof of ownership and appropriate licensing including, but not limited to, proof of purchase, maintaining updated licenses, maintaining the appropriate number of licenses for the Users and systems in use, as to avoid being in breach of contract. All application and system owners must ensure that regular reviews are conducted in order to make sure that only authorized and licensed software is installed and being utilized. This includes ensuring that only the intended Users of the software are in possession and not transferred to unauthorized Users.

Users must also follow the terms and conditions as specified from public networks, including copyright law (i.e. not converting, duplicating in full or partially, or extracting any content that would be in breach of copyright law). Copyright infringement can lead to legal action, which may involve fines and criminal proceedings.

5.6.9. Mobile devices

Mobile computing devices include all kinds of portable computers, mobile phones, smart phones, memory cards and other mobile equipment used for storage, processing and transferring of data.

Organization-owned mobile devices must only be taken off-premises after obtaining authorization from the asset owner. Laptops assigned by the IT Service Desk team to Users as their primary workstation may be taken off-premises.

All Users are responsible for understanding the mobile device standard and best practices for mobile computing equipment and contact the Security team for further inquiries.

Special care should be taken when mobile computing equipment is placed in cars or other forms of transportation, public spaces, hotel rooms, meeting places, conference centers, and other unprotected areas outside the Organization's premises.

The person utilizing a mobile device must follow these rules:

- Mobile computing devices containing important, sensitive, or critical information must not be left unattended and, if possible, must be physically locked away, or special locks must be used to secure the equipment (including off-premise).
- In the case of a mobile device being left unattended, the rules for unattended User equipment must be applied in accordance with the Clear Desk requirements written in the [*Physical and Environmental Protection Standard*](#).

- Users must follow applicable local, state, and federal laws and regulations regarding the use of electronic devices at all times. Users whose job responsibilities include regular or occasional driving are expected to comply with appropriate laws while driving. Users who are charged with traffic violations resulting from the use of their mobile devices while driving will be solely responsible for all liabilities that result from such violations. Users who work in hazardous areas must refrain from using mobile devices while at work in those areas.
- When using mobile computing devices, Users must take care that data cannot be read by unauthorized persons.
- Only approved software, patches, and updates required for business purposes may be installed. Devices which do not comply will have their access revoked, with or without notice.
- All approved patches and updates must be installed regularly. If a patch or update is no longer supported by the Supplier, it must be upgraded or uninstalled.
- When using a mobile device, it is the User's responsibility to avoid connecting to unsupported or unprotected networks.
- If the media of a mobile device contains data with important considerations, or the confidentiality is classified higher than "public," cryptographic techniques must be implemented by the Organization to protect the data. The partition containing the information, at least, must be encrypted to protect the data at rest if the software supports this functionality
- Protection of confidential data or internal use data must be implemented.
- If company-owned, the mobile device is required to be enrolled in the Corporate Mobile Device Management (MDM) program.
- Mobile devices enrolled in the Corporate MDM program must be protected by a password that complies with the password requirements as written in the [Technical Security Standard](#).
- The individual using a mobile device is responsible for regular backups of device data.
- In general, Users must not visit web services and/or web applications that may be malicious.

5.6.9.1. Remote access

Information and communication equipment must be used to enable Users to perform their work outside the Organization using remote access. This does not include the use of mobile phones outside the Organization's premises.

The Enterprise Technology Partners (ETP) team is responsible for preparing plans and procedures to ensure the following, and it is the responsibility of Users to apply it:

- Protection of mobile computing equipment
- Prevention of unauthorized access by persons living or working on the location where the remote access activity is performed
- Appropriate configuration of the local network used for connecting to the Internet

- Protection of the Organization's intellectual property rights, either for software or other materials
- A process for return of equipment and data in the case of termination of employment
- Minimum level of configuration of the facility where remote access activities will be performed
- Permitted and forbidden type of activities are clearly defined

For more information, see the [Technical Security Standard](#).

5.6.9.2. Bring Your Own Device (BYOD)

All Users who use a personal device (mobile phone, tablet, etc.) for company-related work are required to enroll in and comply with the Corporate MDM program, which provides the minimum accepted security best practices for storing, processing, and/or transferring corporate data with/from a personal device. Users are not permitted to connect unapproved personal devices to Corporate networks, including access to the VPN. Users must only connect to the Organization networks which have been defined as "Guest" networks from their unapproved personal devices. Exceptions to this include access to approved public cloud applications.

Users must not locally store the Organization's sensitive information on their personal devices. Company data that is stored, transferred, or processed on a personal device remains under the Organization's ownership.

The Organization does not require that an employee use a personal device for work purposes. Therefore, the Organization will not reimburse or compensate employees for the cost of those devices (including an "expense" for cell phones). The Organization's Users can only expense their cell phone bill if their cell phone is necessary for their job function, and if it complies with the Organization reimbursement policy.

5.7. Handling of assets

Access to assets shall be granted based on User role and the need to know the information. A record of asset owners and authorized recipients for these assets shall be in place and audited yearly, or when a change has been made to verify that the correct authorized recipients of assets are validated.

Storage of assets must be maintained according to the manufacturer's specifications.

For information on how to label physical assets, reach out to the appropriate team manager for documentation on the procedure. The labels must be easily recognizable and the labeling must be consistent with the classifications defined in the [Records Management Standard](#).

Note: If an asset is not labeled, it must be considered as "Internal Use".

5.7.1. Information transfer

Refer to the [Records Management Standard](#).

5.7.2. Media handling

Media is defined as the form and technology used to communicate information. This could include, but is not limited to, hard drives, USBs, mass storage, flash memory cards, CD/DVD, networking equipment, and paper documents.

5.7.2.1. Management of removable media

Management of removable media must be implemented according to the [Records Management Standard](#). The following guidelines for the management of removable media must be considered:

- If no longer required, the sensitive information of any re-usable media that are to be removed from the Organization must be securely deleted
- Users must not copy the Organization's confidential data onto mass storage devices that are not managed by the Organization
- All media must be stored in a secure environment in accordance with the [Records Management Standard](#) and the specifications of the manufacturer
- If the confidentiality or integrity of the data located on the media is a concern, cryptographic techniques must be used to protect it
- If stored data is needed from a device that needs to become unreadable, this data must be transferred to fresh media prior to becoming unreadable
- Valuable data must be stored on separate media to reduce the risk of data damage or loss

5.7.2.2. Physical media in transit

Information may be vulnerable to unauthorized access, misuse or corruption during physical transport. To protect against unauthorized access, misuse, or corruption of computer media being transferred between sites, the Organization shall:

- Use only approved couriers to transport media.
- Protect content during transport by sufficient packaging which respects manufacturers' specifications in order to protect the device from any damage. Damage can include exposure to heat, moisture or electromagnetic fields. Therefore, there must be protections in place to prevent this damage.
- Protect sensitive information through means such as:
 - Use of locked containers
 - Delivery by hand
 - Tamper-evident packaging

- Splitting consignments
- Use of digital signatures and encryption
- Use of mail tracking system

5.7.2.3. Media sanitization and disposal

Refer to the [*Physical and Environmental Protection Standard*](#).

5.7.3. Return of assets

Upon termination of an employment contract or a change in employment, the User must return all organizational assets to the Service Desk, or the asset owner in coordination with the manager of the relevant team. All other information related to employment must be given to the Organization in accordance with the employee's contract.

In cases where an employee or Supplier uses their own personal equipment, the User must ensure that all internal use and confidential information are securely transferred to the Organization and securely erased from their personal machine after termination.

5.8. User passwords

The Organization shall deploy and manage a password management system, such as Entra AD, for all Users at the Organization to ensure quality passwords.

Users must ensure that they are following security best practices which include:

- Keeping secret authentication information confidential and ensuring that it is not divulged to any other parties, including people of authority.
- Avoiding keeping a record (e.g. on paper, software file or hand-held device) of secret authentication information, unless this can be stored securely and the method of storing has been approved (e.g. password vault).
- Changing secret authentication information whenever there is any indication of its possible compromise.
- A minimum of 13 characters is required, while a minimum of 16 characters is recommended using a combination of all four (4) character types (uppercase and lowercase letters, numbers, and symbols).

Passwords shall:

- Change every 90 days
 - Not be based on anything easily guessable or obtainable using person related information, e.g. names, telephone numbers, dates of birth, etc.
 - Not consist of words included in dictionaries making them vulnerable to dictionary attacks
 - Be free of consecutive identical, all-numeric or all-alphabetic characters
 - If temporary, passwords shall change at the first log-on
- The Organization shall enforce a password history policy which stores previous passwords and prevents Users from reusing them within five (5) password changes.
 - When allocating and using User passwords:
 - Users must keep passwords confidential
 - Each User may use only his/her own uniquely allocated username
 - Each User must have the option to choose his/her own password, where applicable
 - Compile Management of secret authentication information of Users
 - The password must not be visible on the screen during log-on
 - Passwords created by the software or hardware manufacturer must be changed during initial installation

For more information, see the [Technical Security Standard](#).

5.8.1. Application service account passwords

Application service account credentials must be stored in a vault with the Privileged Access Management system, and retrieved dynamically by the application at runtime.

If vaulting is not yet implemented, credentials must be rotated at least every 180 days. Any deviation from this requirement must be documented and approved through a formal exception process, including a remediation plan to eliminate hardcoded secrets.

5.9. Network security

The Organization shall have a comprehensive approach to securing information systems, for example: firewalls, routers, switches, and so on.

- Maintain standard configurations
- Divide its information systems into manageable logical network segments to reduce the scope of compliance, limit data exfiltration, and reduce the attack surface
- Perform periodic Vulnerability Assessments (network scans) of networked systems to determine if the systems are vulnerable

For more information, see the [Technical Security Standard](#).

5.10. Physical access control

The Organization shall maintain methods and processes that clearly identify and distinguish physical access for employees, contractors, and visitors to locations housing Company information systems.

- Company information systems must be physically secure
- Physical access shall be controlled by an Access Control System meeting the requirements of the [Physical and Environmental Protection Standard](#) for all locations where employees have access to sensitive data
- Users requiring access to Organizational communications sites and data centers must submit a request for approval by a company vice president or above
- Visitors requiring access to Organizational communications sites and data centers must be escorted by an appropriate Zayo employee
- Visitors must sign a visitor's log prior to being granted access to Organizational secure areas. The log must document the visitor's name, the company represented, the authorizing Zayo employee, and the date & time of entrance and departure

5.11. Endpoint protection

The Organization shall maintain an endpoint protection program, which shall include an anti-virus solution. Anti-virus software shall be kept actively running and capable of generating audit logs. Users are prohibited from taking any action that may either disable or otherwise materially disrupt the installation and/or running of the anti-virus software on Company-owned endpoints.

The anti-virus solution shall be installed on all endpoints and configured to be updated on a continuous basis.

5.11.1. Endpoint encryption

All company-owned mobile devices containing company data must use an approved method of encryption to protect data at rest. Mobile devices are defined to include laptops and company-owned cell phones. Laptops must employ full disk encryption with an approved software encryption package. No company data may exist on a laptop in plain text. The loss or theft of any mobile device containing company data must be reported immediately.

5.12. Incident response

Any incident that has a significant impact on the continuity, availability, confidentiality, or integrity of customer critical services must be promptly reported, identified, and classified. This includes cyber incidents, data breaches, and operational disruptions. Reporting mechanisms include automated detection tooling, incident tickets using the [ServiceNow Employee Center](#) or contact Security directly via security.support@zayo.com. The Organization shall respond to security incidents to the extent possible in order to mitigate the potential impact to Organizational information systems and data.

The Organization shall maintain and periodically update, as required, policies and procedures designed to:

- Identify and respond to security incidents as documented
- Mitigate, to the extent possible, any potential impact of known Security Incidents
- Document any security incidents and their outcomes
- Allow Users to report suspicious actions, activities and incidents to Desktop Support
- Maintain a documented Incident Management Plan
- Perform periodic simulation exercises to test the practical readiness of incident response protocols and third-party breach handling

For more information, see the [Operational and Systems Continuity Standard](#) and the [Enterprise Incident Management Plan](#).

5.13. Vulnerability and patch management

The Organization shall maintain Vulnerability and Patch Management programs to regularly identify, prioritize, and deploy patches and updates associated with information systems. These programs shall implement threat and file integrity monitoring controls, including regular penetration testing and vulnerability scanning, to identify networked assets and data protection incidents to determine and assess potential vulnerabilities:

- Quarterly scans shall be performed for internal/external network vulnerabilities by qualified internal resource(s)
- If automated, alerts shall notify the Security personnel
- Rescans, if required, shall be performed, following any anomalies
- Vulnerabilities shall be remediated according to the **Patching schedule priority matrix** as documented in the [Technical Security Standard](#)

5.14. Log retention and management

The Organization shall identify high priority information systems and shall retain log data for a period of one year with the past 90 days immediately available.

5.15. Change management

The Organization shall maintain a Change Management program to include planning, coordinating, implementing and monitoring changes affecting any production platform.

For more information, see the [Operational Management Standard](#).

6. Security awareness training

The Organization shall regularly provide information security awareness training to its Users via methods such as login banners, posters, web-based training, emails and periodic brown bag sessions.

Such information may include significant revisions to:

- Security Governance documentation
- Company information security controls or processes
- Information security best practices, including phishing, viruses, and malware
- Periodic simulation exercises to test the practical readiness of incident response protocols and third-party breach handling as part of the Enterprise Resilience program

For more information, see the [Human Resources Management Standard](#) and [Operational and Systems Continuity Standard](#).



6.1. External User training

6.1.1. Vendors providing services onsite

Vendors who have access to Zayo facilities may/may not be badged or require an escort (e.g. Shredding Company, Deliveries (coffee, tea, etc.), and Cleaning Crews). They cannot access any corporate business system or sensitive data. This type of vendor does not have to acknowledge any written policies.

6.1.2. Contributing contractors to Zayo deliverables

External individual contractors hired to augment Zayo staff and contribute to Zayo deliverables (i.e., code, database manipulation, documentation, and reporting) are issued Zayo email address and may access sensitive Zayo development/test/production applications, systems or data (e.g. financial, accounting, customer, employee, source code, and circuit information, etc.). This type of contractor must complete full training.

6.1.3. Contractors supporting Zayo

External companies hired on a project or support contract basis must be vetted during the vendor onboarding process, including looking at any relevant IT, security, and compliance requirements which may be applicable. Due diligence monitoring should be conducted on a periodic basis based upon the types of services being provided to the organization and the impact to security, availability, or the integrity of data.

This type of contractor must, on an annual basis, acknowledge the *Zayo Security Policy*.

Managers of these contractors shall ensure and are responsible that each contractor reads and understands and acknowledges the documents above. External companies who have more than one contractor working with Zayo employees, as described above, may not sign a single acknowledgement on behalf of all contractors working for that company.

7. Release of Information

Zayo often receives inquiries to release Security files, records, plans and procedures. This Policy is documented to set forth guidelines for the release of Zayo proprietary information.

- All Security materials shall be reviewed and approved prior to release to ensure that the release of information follows this Policy
- If there is a question whether the requested material release follows this Policy, the CSO shall make final determination for the release and may consult with Legal, if appropriate

- Material containing the following shall not be released in its entirety:
 - United States Government Customer Account data
 - Personal Identification Information of any kind, specifically:
 - Employee names, personal and work contact information
 - Customer names and contact information
 - Partner/Agent names and contact information
 - IP Addresses
 - Sensitive Corporate information (financial, legal, operational, and technology information)
 - Classified information (how our internal and external networks operate)
 - Specific continuity/recovery details and strategies, including hardware, and software information (leading to the rebuilding of or restoration of our service provider network)
- Where a customer Service Level Agreement (SLA) or other contract has been signed that requires the release of specific information contained in an electronic file, and if the above conditions exist, only the Table of Contents (TOC) will be released for said electronic file
- All material released to customers or external entities shall only be in PDF format

8. Control objectives

Per the [Monitoring and Measurement Standard](#), the effectiveness of security controls and overall policy adherence are monitored and managed through KPIs.

Control Objective	Description
Leadership and High Level Objectives	The Organization shall implement controls related to organizational leadership, governance, and the establishment of high-level objectives including strategic planning, policy development, and leadership responsibilities for security compliance. Please refer to the Leadership and High Level Objectives Standard .
Monitoring and Measurement	The Organization shall implement controls involving the ongoing monitoring and measurement of processes, systems, and activities to ensure compliance, detect anomalies, and assess performance. Please refer to the Monitoring and Measurement Standard .

Control Objective	Description
Audits and Risk Management	The Organization shall implement controls associated with conducting audits, managing risks, and implementing risk mitigation strategies, including risk assessments, risk treatment plans, and audit processes. Please refer to the Audits and Risk Management Standard .
Technical Security	The Organization shall implement controls related to technical aspects of security, such as access controls, encryption, network security, and other measures to protect information systems. Please refer to the Technical Security Standard .
Physical and Environmental Protection	The Organization shall implement controls aimed at safeguarding physical assets, facilities, and environmental conditions that impact the security and availability of information systems. Please refer to the Physical and Environmental Protection Standard .
Operational and Systems Continuity	The Organization shall implement controls related to ensuring the continuity of operations and systems such as business continuity planning, disaster recovery, and incident response. Please refer to the Operational and Systems Continuity Standard .
Human Resources Management	The organization shall implement controls that address the management of personnel security, training, awareness, and the implementation of security policies. Please refer to the Human Resources Management Standard .
Operational Management	The Organization shall implement controls related to the day-to-day operations of an organization, covering areas such as change management, incident management, and configuration management. Please refer to the Operational Management Standard .
Systems Hardening Through Configuration Management	The Organization shall implement controls to securely configure and manage information systems to reduce vulnerabilities and enhance overall security. Please refer to the System Hardening Through Configuration Management Standard .

Control Objective	Description
Records Management	The Organization shall implement controls associated with the proper management, retention, and disposal of records and information in compliance with legal and regulatory requirements. Please refer to the Records Management Standard .
Systems Design, Build, and Implementation	The Organization shall implement controls related to the secure design, development, and implementation of information systems to ensure they meet security requirements. Please refer to the Systems Design, Build, and Implementation Standard .
Acquisition or Sale of Facilities, Technology, and Services	The Organization shall implement controls related to the acquisition or sale of assets, technology, and services, ensuring that security considerations are taken into account. Please refer to the Acquisition or Sale of Facilities, Technology, and Services Standard .
Privacy Protection for Information and Data	The Organization shall implement controls related to the protection of privacy in the processing and handling of personal information and sensitive data. Please refer to the Privacy Protection for Information and Data Standard .
Harmonization Methods and Manual of Style	The Organization shall implement controls related to standardizing methods, processes, and documentation styles for consistent application across the organization. Please refer to the Harmonization Methods and Manual of Style Standard .
Third Party and Supply Chain Oversight	The Organization shall implement controls related to managing and overseeing third-party relationships, including supply chain security and vendor risk management. Please refer to the Third Party and Supply Chain Oversight Standard .

9. Roles and responsibilities

Owner: Shawn Edwards

Role	Responsibilities
All Personnel	• Maintain the security of information and information systems on a day-to-day basis • Provide the first line of defense in keeping information systems secure • Comply with the security procedures and practices outlined within this Policy and other relevant supporting Organization policies and standards • Report all security incidents or weaknesses to the Security team • Annually or upon hire, review, understand and acknowledge this Policy via the tool provided • Annually or upon hire, review, understand and acknowledge the Security Awareness Training provided via the tool provided
Asset Owners	Protect the integrity, availability, and confidentiality of assets under ownership
Chief Executive Officer (CEO)	• Delegates to the Chief Security Officer (CSO), on behalf of the Organization's Executive Leadership Team, to take overall responsibility for the general development and implementation of Information Security and to support the identification of controls that need to be met • Sets the tone for the Organization's attitude towards security • Involved in strategic planning of security initiatives • Allocates resources to ensure the Organization has the tools, technologies, and staff required to implement effective security measures • Communicates to the board regarding the Organization's performance, risks, and strategic direction • Ensures the Organization's compliance with relevant laws and regulations • Fosters culture of continuous improvement in security
Chief Information Officer (CIO)	Key stakeholder and governance control owner
Chief Operating Officer (COO)	Key stakeholder and governance control owner

Role	Responsibilities
Chief Security Officer (CSO)	- Ensures the Zayo Security Policy and objectives are established and are compatible with the strategic direction of the Organization - Ensures the integration of the Information Security Management System (ISMS) requirements into the Organization's processes - Ensures that the resources needed for the ISMS are available - Communicates the importance of effective Information Security Management and of conforming to the information security management system requirements - Ensures that the ISMS achieves its intended outcome(s) - Directs and supports Users to contribute to the effectiveness of the ISMS - Supports other relevant management roles to demonstrate their leadership as it applies to their areas of responsibility - Continually improves the suitability, adequacy and effectiveness of the ISMS - Maintains awareness of all relevant legislation and to inform the board on any changes to security legislation and regulations, and other requirements to which the Organization subscribes that will have an impact on the Organization's operations and subsequently any changes that will be required to the ISMS - Authorizes changes to ISMS objectives, targets and programs which are recommended and agreed upon by the Security team - Directs and supports all Users contributing to the effectiveness of the ISMS - Provides final approval to policies, standards, and exceptions - Monitors overall performance of the Security Governance Framework - Reviews and approves new documents, document retirements, and exceptions - Reviews and approves material updates to existing documents
Consultant	Persons doing work under an Organization purchased vendor professional service. Consultants are typically either project-based (tied to a deliverable end date) or time-based (Statement of Work defined end date). See also <i>Vendor</i> .
Contractor	Persons hired through a temporary staffing service or as independent contractors. Staffing service contractors have end dates as defined in the staffing service agreement, while independent contractors are either hourly or project-based with a deliverable end date.

Role	Responsibilities
Incident Response Team	- Responsible for handling and mitigating security incidents, such as data breaches or cyberattacks - Develop and implement incident response plans, coordinate response efforts, and work to minimize the impact of security incidents
Privileged Users	- Human Resources - Workday Admins - Information Technology - Domain Admins - Linux Admins - Network Admins - Legal - Executives - Executive Admins
Security Team	- Coordinate the Security Governance Framework life cycle, including implementation with Standards owners and project teams - Maintain a document database (log) (or other storage platform) - Ensure documents are up-to-date (i.e. facilitate review process) - Review and approve non-material updates to existing documents - Support the document owner with communication and training needs - Review all documents and changes before submission for approval
Supplier	Vendors and partners are referred to as "Supplier" throughout all Organization Policies. See also <i>Vendor</i> .
Vendor	Vendors provide professional service consultants, outsourced workers, or products to the Organization. See also <i>Consultants</i> and <i>Vendor Worker</i> .
Vendor Worker	A person working for the Organization on behalf of a vendor for a specified period of time, for example, employees of TCS. The Organization shall enhance vendor oversight by requiring regular audits and certifications to strengthen compliance and reduce risks related to Supplier dependencies.

10. Definitions

Term	Definition
Access Control	A means to ensure that access to assets is authorized and restricted based on business and security requirements.
Attack	An attempt to destroy, expose, alter, disable, steal or gain unauthorized access to or make unauthorized use of an asset.
Authentication	A provision of assurance that a claimed characteristic of an entity is correct.
Authoritative Directory Services	LDAP and/or Active Directory services
Authoritative Source	Regulatory guidance, standards, requirements, and best practices to ensure confidentiality, integrity, and availability of information that shape and maintain effective information security practices.
Availability	A property of being accessible and usable upon demand by an authorized entity.
Confidentiality	A property that information is not made available or disclosed to unauthorized individuals, entities, or processes.
Consultant	Persons doing work under an Organization purchased vendor professional service. Consultants are typically either project-based (tied to a deliverable end date) or time-based (Statement of Work defined end date) - see also <i>Vendor</i> .
Contractor	Persons hired through a temporary staffing service or as independent contractors. Staffing service contractors have end dates as defined in the staffing service agreement, while independent contractors are either hourly or project-based with a deliverable end date.
Control	A measure that modifies risk. Controls include any process, policy, device, practice, or other actions that modify risk. Controls may not always exert the intended or assumed modifying effect.

Term	Definition
Control Objective	A common objective for a set of controls built from authoritative source citations to set parameters or configurations that support policy.
Data Classification	A method for defining and categorizing files and critical business information.
Data Custodian	May deliver technical protection of information assets, such as data. Backing up data in line with Organization Standards, restoration of data, patching systems, and configuring antivirus software are some of the most common tasks within the scope of duties of data custodians.
Data Owner	Accountable for who has access to information assets within their functional areas. A Data Owner may decide to review and authorize each access request individually or may define a set of rules that determine who is eligible for access based on business function, support role, etc.
Endpoint	Physical devices that connect to and exchange information with a computer network.
Event	An occurrence or change of a set of circumstances; any observable occurrence in a network or system.
Incident	An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use standards.
Incident Response	An organized approach to addressing and managing the aftermath of a security breach or attack (also known as an incident). The goal is to handle the situation in a way that limits damage and reduces recovery time and costs.
Information Security	The preservation of confidentiality, integrity, and availability of information.
Information Security Incident Management	Processes for detecting, reporting, assessing, responding to, dealing with, and learning from information security incidents.

Term	Definition
Information Systems	Information systems include all types of electronic systems processing data like laptop computers, tablets, desktop workstations, servers, mainframe computers, routers, switches, cell or “smart” phones, personal digital assistants, wired telephones, and fax machines.
Integrity	A property of accuracy and completeness.
Monitoring	A method of determining the status of a system, a process, or an activity.
Patch Management	The process of acquiring, testing, and distributing patches to the appropriate administrators and users throughout the organization and installing, and verifying patches for products and systems.
Process	A set of interrelated or interacting activities which transforms inputs into outputs.
Reliability	A property of consistent intended behavior and results.
Requirement	The need or expectation that is stated, generally implied, or obligatory. Note: “Generally implied” means that it is custom or common practice for the Organization and interested parties that the need or expectation under consideration is implied.
Risk	An effect of uncertainty on objectives.
Stakeholder	A person or organization that can affect, be affected by, or perceive themselves to be affected by a decision or activity.
Supplier	Vendors and partners are referred to as “Supplier” throughout all Organization Policies and Standards.
Technology Owner	The system or server owner who manages the staff that is responsible for securing the Organization’s infrastructure; owns the patching and updating of operating systems and hardens the system to the greatest degree possible to prevent any breaches. Technical hands-on tasks are usually delegated to Systems Administrators, or Data Custodians.

Term	Definition
Threat	A potential cause of an unwanted incident, which may result in harm to a system or organization.
Vendor	Vendors provide professional service consultants, outsourced workers, or products to the Organization - see also <i>Consultants</i> and <i>Vendor Worker</i> .
Vendor Worker	A person working for the Organization on behalf of a vendor for a specified period of time, for example, employees of TCS - see also <i>Vendor</i> .
Vulnerability	A weakness that allows an attacker to reduce a system's information assurance. Vulnerability is the intersection of three elements: a system susceptibility or flaw, attacker access to the flaw, and attacker capability to exploit the flaw.

11. Enforcement

Executive Leadership will enforce this Policy. Non-compliance with this Policy may be considered a breach of the Code of Conduct and subject to action by Human Resources.

Any violations of the Policy may be escalated to and reviewed by Security, Legal, or other stakeholders for recommended enforcement action.

12. Related documents

The following documents are referenced within this Policy or contain additional requirements for compliance:

- [Security Governance Framework](#)
- [Acquisition or Sale of Facilities, Technology, and Services Standard](#)
- [Audits and Risk Management Standard](#)
- [Harmonization Methods and Manual of Style Standard](#)
- [Human Resources Management Standard](#)
- [Leadership and High Level Objectives Standard](#)
- [Monitoring and Measurement Standard](#)
- [Operational and Systems Continuity Standard](#)
- [Operational Management Standard](#)

- [Physical and Environmental Protection Standard](#)
- [Privacy Protection for Information and Data Standard](#)
- [Records Management Standard](#)
- [Systems Design, Build and Implementation Standard](#)
- [Systems Hardening Through Configuration Management Standard](#)
- [Technical Security Standard](#)
- [Third Party and Supply Chain Oversight Standard](#)

13. Validity and policy management

This Policy is valid as of the date in the change history.

The owner of this Policy is the Security team, who must review and, if necessary, update the Policy at least once a year. Semi-annual updates may occur to ensure relevance of high-risk sections such as AI and Cloud Security amid rapidly evolving threats and regulations.